BOTIUM TOYS: COMPREHENSIVE INTERNAL SECURITY AUDIT REPORT

Security Program Assessment, Controls Checklist, Compliance Evaluation, and Executive Recommendations

---

Prepared For: IT Manager & Stakeholders	**Date:** October 2026
Organization: Botium Toys	**Overall Risk Score:** 8 / 10 (High Risk)

1. Executive Summary & Audit Scope

This comprehensive internal security audit evaluates Botium Toys' complete security posture, asset management practices, technical control implementations, and adherence to key regulatory frameworks (PCI DSS, GDPR, and SOC 1 / SOC 2). Based on our findings, Botium Toys currently operates at a **High Risk level (8/10)** due to significant gaps in access controls, lack of data encryption, absence of intrusion detection and disaster recovery mechanisms, and non-compliant password management.

Audit Scope: Encompasses the entire security program at Botium Toys, including all organizational assets, internal processes, procedural controls, and compliance best practices across on-premises, remote, and storefront environments.

Audit Goals: Assess existing assets, complete rigorous controls and compliance checklists, and formulate actionable recommendations to bridge security gaps and protect critical organizational data.

2. Asset Inventory & Current Infrastructure

Assets managed by the IT Department span multiple domains and require structured classification and impact analysis under the NIST CSF *Identify* function:

• **On-Premises Equipment:** Hardware supporting in-office business operations, physical offices, storefront, and warehouse.

• **Employee Equipment:** End-user devices (desktops, laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, and surveillance cameras.

• **Inventory & Warehouse:** Storefront products available for retail sale on-site and online, stored in the adjoining company warehouse.

• **Software & Systems:** Management systems for accounting, telecommunications, databases, security, e-commerce, and inventory management.

• **Network & Infrastructure:** Internet access, internal network routing, data retention stores, and legacy system maintenance (end-of-life systems requiring manual monitoring).

3. Risk Assessment & Findings

Risk Score: 8 / 10 (Fairly High Risk). This elevated score stems from a widespread lack of technical controls and incomplete adherence to regulatory compliance standards.

Impact Analysis: The potential impact resulting from the loss of an asset is rated as **Medium** because the IT department currently lacks comprehensive asset visibility. Conversely, regulatory fines and security exposure are rated as **High** due to unencrypted cardholder data, unchecked employee access, and absence of backups.

Key Security Findings:

- **Data Access:** All employees currently possess broad access to internally stored data, potentially exposing cardholder data and customer PII/SPII.
- **Encryption:** Customer credit card information accepted, processed, transmitted, and stored locally in internal databases is unencrypted.
- **Access Controls:** Principles of Least Privilege and Separation of Duties have not been implemented.
- **Network Defense:** While firewalls block traffic via defined rules and antivirus software is actively monitored, **no Intrusion Detection System (IDS)** is installed.
- **Disaster Recovery & Backups:** No disaster recovery plans exist, and critical data backups are currently absent.
- **Password Policies & Management:** Password requirements are nominal (at least 8 characters, letters and a number) and lack special characters. There is no centralized password management system, leading to operational friction and ticket backlog for password resets.
- **Legacy Systems:** Legacy end-of-life systems are maintained and monitored manually without a regular schedule or clear intervention protocols.
- **Physical Security:** Excellent physical security controls, including robust locks, up-to-date CCTV surveillance, and functioning fire detection and suppression systems.

4. Controls Assessment Checklist

The following table evaluates whether Botium Toys currently has essential security controls in place:

Control	Status	Assessment & Notes
Least Privilege	**No**	All employees have broad access to internal data, PII, and cardholder data.
Separation of Duties	**No**	Not currently implemented across operational roles.
Disaster Recovery Plans	**No**	No disaster recovery plans currently in place.
Password Policies	**Yes**	Nominal policy exists, but requires hardening (special characters, complexity).
Firewall	**Yes**	Configured with appropriately defined security rules blocking unauthorized traffic.
Intrusion Detection System (IDS)	**No**	Not installed; network traffic lacks automated anomaly detection.
Backups	**No**	No backups of critical data currently maintained.
Antivirus Software	**Yes**	Installed and monitored regularly by the IT department.
Legacy System Maintenance	**Yes**	Manually monitored and maintained, though lacking a regular schedule.
Encryption	**No**	Credit card information and local database records are unencrypted.
Password Management System	**No**	No centralized password manager; heavy reliance on IT support tickets.

Physical Locks (Offices/Warehouse)	**Yes**	Sufficient physical locks protecting main offices and storefront/warehouse.
CCTV Surveillance	**Yes**	Up-to-date closed-circuit television monitoring active.
Fire Detection & Prevention	**Yes**	Functioning fire alarms and sprinkler systems installed.

5. Compliance Evaluation Checklist

Evaluation of adherence to major regulatory and governance frameworks:

Framework & Best Practice	Status	Evaluation Details
PCI DSS: Authorized access to credit card data	**No**	All employees currently have access to internal data stores.
PCI DSS: Secure environment for card data	**No**	Card data is stored, accepted, and processed locally without secure segmentation.
PCI DSS: Data encryption procedures	**No**	Encryption is not utilized for credit card information.
PCI DSS: Secure password management policies	**No**	Password policies are nominal and lack centralized enforcement.
GDPR: EU customers' data kept private/secure	**No**	Deficiencies in access controls and encryption risk EU customer data.
GDPR: 72-hour breach notification plan	**Yes**	Plan is established to notify EU customers within 72 hours of a breach.
GDPR: Data classification and inventory	**No**	Assets and data stores are not yet classified or fully inventoried.
GDPR: Enforce privacy policies and procedures	**Yes**	Privacy policies developed and enforced among IT members and employees.
SOC 1 & 2: User access policies established	**No**	Lack of Least Privilege and access controls.
SOC 1 & 2: Confidential sensitive data (PII/SPII)	**No**	Unrestricted employee access compromises PII confidentiality.
SOC 1 & 2: Data integrity assurance	**Yes**	IT department has integrated controls to ensure data integrity.
SOC 1 & 2: Data availability for authorized users	**Yes**	IT department ensures operational data availability.

6. Recommendations & Strategic Roadmap for IT Manager

To reduce asset risk, lower vulnerability to regulatory fines, and significantly improve Botium Toys' overall security posture, we recommend that the IT Manager communicate the following phased roadmap to key stakeholders:

1. Implement Asset Classification and Inventory (NIST CSF Identify)

Dedicate immediate resources to inventory and classify all IT assets, hardware, software, and data repositories. Determine business continuity impact upon asset loss.

2. Enforce Principle of Least Privilege and Role-Based Access Control (RBAC)

Restrict internal data access so that employees only access data strictly required for their roles, protecting customer PII/SPII and cardholder data.

3. Deploy End-to-End Encryption

Implement robust encryption standards for all credit card information accepted, processed, transmitted, and stored in local company databases to achieve PCI DSS compliance.

4. Deploy an Intrusion Detection System (IDS)

Install and configure an IDS alongside existing firewalls and antivirus software to monitor network traffic for malicious activity and unauthorized intrusion attempts.

5. Establish Disaster Recovery and Automated Backup Solutions

Develop a comprehensive disaster recovery plan and institute automated, regular backups of critical company and customer data with offsite or secure cloud redundancy.

6. Modernize Password Policies and Deploy Centralized Password Management

Update password complexity requirements (incorporating special characters and minimum length) and deploy a centralized enterprise password manager to eliminate IT support ticket bottlenecks and secure credentials.